codigo

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Aqui está a análise detalhada passo a passo do arquivo `codigo.py` para determinar sua natureza:

1. Visão Geral do Arquivo

O arquivo `codigo.py` (também referido internamente como `bendi.py`) é um script abrangente em Python projetado para automatizar a varredura de rede, testes de força bruta em serviços SSH, propagação maliciosa (comportamento de *worm*), instalação de agentes de controle e persistência em sistemas Linux comprometidos.

2. Análise Passo a Passo dos Componentes

Passo A: Varredura de Portas e Descoberta de Alvos

Uso do `masscan`: O script verifica e instala ferramentas de varredura em massa (`masscan`) para escanear faixas de IPs definidas em `ip_ranges.txt` à procura de portas SSH abertas (especificamente as portas `22` e `5522`). `PY`

Extração de Dados (`ip_port_extractor.py` **):** Processa a saída bruta do `masscan` para isolar os endereços IP e portas em um formato padronizado (`ip:port`). `PY`

Passo B: Ataque de Força Bruta / Credenciais Padrão (`ssh_scanner.py`)

O script utiliza a biblioteca `paramiko` para realizar conexões SSH automatizadas e multi-thread em larga escala. `PY`

Ele testa credenciais pré-definidas e comuns (como usuário `root` combinado com senhas fracas ou específicas como `LeitboGi0ro` e `123@@@`) contra os alvos descobertos. `PY`

Os IPs bem-sucedidos (onde o acesso foi obtido) são salvos em arquivos de texto e adicionados a uma lista de exclusão (`del.txt`). PY

Passo C: Propagação Automática e Infecção Lateral (`monitor_script.py`)

O componente monitor (`monitor_script.py`) vigia continuamente os diretórios de resultados de varredura. PY

Ao identificar um novo host vulnerável, o script **conecta-se automaticamente via SSH** à máquina vítima, **faz o upload de uma cópia de si mesmo** (`bendi.py`), instala o Python3 caso necessário, e executa o payload remotamente. Isso caracteriza o comportamento clássico de um **Worm (verme) auto-propagável**. PY

Passo D: Instalação de Payloads Secundários e Monetização

O script baixa e executa scripts de instalação externos de domínios associados (ex: `del.sou.pp.ua`) para instalar softwares secundários não autorizados, como:

Komari Agent (ferramenta de controle/botnet). PY

TraffMonetizer (ferramenta de compartilhamento de largura de banda para monetização). PY

Realiza consultas e registros em uma API centralizadora (`sou.pp.ua/add_ip.php`) para controlar quais hosts já foram processados/infectados. PY

Passo E: Persistência e Evasão

Serviços `systemd` : O script cria e ativa serviços persistentes no sistema operacional (`scan-runner.service` e `file-monitor.service`) configurados para reiniciar automaticamente em caso de falha e rodar permanentemente com privilégios de `root` . PY

Notificações via Telegram: Integra um token de bot do Telegram (`Telegram Bot API`) e um Chat ID hardcoded para reportar em tempo real o sucesso das invasões e detalhes dos servidores comprometidos. PY

Autodeleção: Após concluir a instalação e configuração inicial no sistema local, o script executa um comando para apagar o próprio arquivo de execução (`rm -- '{this_script_path}'`) com o objetivo de dificultar a análise forense básica. PY

3. Conclusão Final

Este arquivo é um malware.

Trata-se especificamente de um **script de infecção e propagação de botnet (Worm SSH)** altamente estruturado. Ele combina varredura de rede não autorizada, ataques de força bruta a credenciais SSH, infecção lateral automatizada de novos servidores, instalação de backdoors/agentes de mineração ou tráfexo, persistência via serviços do sistema e exfiltração de dados de controle para servidores de Comando e Controle (C2)

Qual é a categoria principal deste malware?

A categoria principal deste malware é a de um **Worm (Verme) SSH** combinado com funcionalidades de **Botnet**.

Esta classificação justifica-se pelas seguintes caraterísticas centrais presentes no código:

Worm de Auto-propagação: O script identifica autonomamente novos alvos na rede através de varreduras (`masscan`), executa ataques de força bruta a credenciais SSH, infeta as máquinas vítimas ao copiar-se a si próprio e executa-se de forma a alargar a rede de computadores comprometidos.

Botnet / Ferramenta de Controlo Remoto: Estabelece persistência no sistema (via serviços `systemd`), reporta o sucesso das invasões através de canais de comunicação externos (como a API do Telegram) e descarrega payloads adicionais (como agentes de controlo e software de tráfego) comandados a partir de infraestruturas externas.